

Nathaniel Abera

07/15/2026

D828 Task 1: Information Security Policy Analysis

A. The organization I chose was TeleMedica, a healthcare company operating in the United States that focuses on providing consumers with virtual healthcare services. It connects patients virtually with professional doctors, specialists, and psychiatrists worldwide. Its services include remote consultations and health monitoring, AI diagnostics, and telepsychiatry. The company has a sister company, MediCom GmbH, based in Berlin, Germany, where it also offers its services. TeleMedica is not only committed to providing its consumers with excellent services but it also values transparency and data security of its patient information by following industry standards and regulations. The company's policy frames data privacy as its commitment to transparency, lawfully and securely processing data while protecting confidentiality, integrity, and availability of the information. TeleMedica handles patient health and personal information as well as internal business data which it classifies with labels ranging from public to restricted. The data is the absolute foundation of the company, as all the services TeleMedica has to offer depend on it, which makes keeping it protected and maintaining regulatory compliance a necessity to its daily operations.

B. I identified two frameworks that informed the development of the TeleMedica Information Security Policy. The first is the NIST Cybersecurity Framework (CSF) which is built around managing cybersecurity risk through its core functions: Identify, Protect, Detect, Respond, and Recover. The language of the policy points directly to the framework as it states verbatim "These frameworks

ensure that our approach to information security is proactive, risk-based, and aligned with recognized best practices” (TeleMedica, n.d.). This proactive wording advocates for managing risk and mirrors the CSF approach.

The second framework that I identified within the TeleMedica Information Security Policy is ISO/IEC 27001. This framework is an international standard for information security management systems (ISMS), and the main objective of this framework is preserving confidentiality, integrity, and availability. Because the company policy is driven by its three core principles “protecting the confidentiality, integrity, and availability of all sensitive and critical information assets” (TeleMedica, n.d.), it reflects the ISO 27001 framework.

C. The two security standards that I matched with TeleMedica’s information security policy were NIST SP 800-61 and NIST SP 800-88 because both standards align directly with the company policy. First, NIST SP 800-61 defines how organizations should handle security incidents. Its core incident response begins with preparation, followed by detection and analysis, then containment, eradication, and recovery, and ends with post-incident activity. When looking at the information security policy of TeleMedica it states verbatim “Incidents are managed using the Detect, Analyze, Contain, Eradicate, and Recover (DACER) methodology” (TeleMedica, n.d.). Every step of the DACER methodology the company currently follows aligns directly with the SP 800-61 lifecycle.

The second standard I matched with TeleMedica was NIST SP 800-88 whose guidelines require that data destroyed must not be recoverable. The Data Protection and Privacy Policy procedures specifically state “Sensitive data is permanently deleted from the system using an enterprise-approved data destruction tool when data is no longer needed” (TeleMedica, n.d.). If the deletion of TeleMedica was ordinary and recoverable it would not align with

this NIST standard but because its policy states that the company uses an enterprise-approved data destruction tool, it does align with NIST SP 800-88.

D. The first procedure that TeleMedica does for data protection is data classification and labeling. Based on its policy, the company classifies data into multiple levels: Public, internal, confidential, and restricted. No data is left unlabeled. Restricted data is the strongest protected data, as it is encrypted and stored in a secure data vault. The reason that this is effective is that once data is classified under a specific label it now gets matched to a certain protection level. If data is not labeled, then protection becomes difficult because not all data deserves the same level of protection. The NIST SP 800-60 is a standard for categorizing information by impact level which aligns with the procedures done by the company.

The second procedure, least privilege access control, limits the amount of access employees have on patient information and only grants access based on specific roles of TeleMedica's employees. The reason that this is effective is that it shrinks the number of people who have access to certain kinds of information within the company. This makes it easier for the review team to identify any potential entry points if anyone is compromised as a hypothetical attacker could only access specific data based on whatever role the attacker compromised. The NIST SP 800-53 control AC-6 (Least Privilege) aligns exactly with the company as it details the level of access which should be given based on roles.

The third procedure is data minimization with quarterly reviews. This focuses on only collecting essential data and reviewing data fields regularly with the deletion of any no longer needed data. Any data that is never collected cannot be breached by attackers. Storing less data allows the company to be a smaller target. Quarterly reviews help stop the company from keeping data that it no longer needs. As stated in the NIST Privacy Framework, data

minimization is a core principle.

E. TeleMedica provides telehealth services worldwide. The company has data centers based in the United States and the United Kingdom. In the United States, the company operates and stores its patient data on its cloud data center servers in the state of California. Although TeleMedica serves multiple states, it also serves and collects data from consumers based in California. This means TeleMedica must comply with the California Consumer Privacy Act (CCPA), a state law that gives consumers multiple rights such as the right to be knowledgeable about how their data is being used, the right to delete it if they want, and it requires businesses to collect only the necessary information to conduct operations (California Department of Justice, 2024).

TeleMedica demonstrates its CCPA compliance based on its disposal and data collection procedures it has in place. In the company's Data Protection and Privacy Policies the company clarifies that the business only collects necessary information, and the employees review required data fields quarterly. The company also ensures that consumers' sensitive data is properly disposed of by using an enterprise-approved tool that deletes information of consumers in its entirety which facilitates the right of data deletion (TeleMedica, n.d.).

Since TeleMedica is a healthcare provider in the United States the company is required by law to comply with the Health Insurance Portability and Accountability Act (HIPAA), a federal law that sets national standards for protecting the health information of patients. Based on HIPAA, having security protocols in place is needed. Implementing safeguards such as encryption, access controls, and regular audits are necessary HIPAA requirements for protecting patient health information (U.S. Department of Health and Human Services, 2013). This information is the core of how TeleMedica operates its business. The company uses patient health information between its internal systems and AI health monitoring software

daily. Because the company transmits and stores protected health information electronically it is classified as a covered entity under HIPAA (TeleMedica, n.d.).

TeleMedica keeps patient records safe by encrypting sensitive data and storing it in a secure data vault. Access to patient information is entirely based on roles and follows the least privilege principle. TeleMedica has a dedicated IT security team that regularly audits these privileges biannually. These procedures reflect what is required under HIPAA's Security Rule (TeleMedica, n.d.).

TeleMedica also has a sister company, MediCom GmbH, that it collaborates with in Berlin, Germany. This requires the company to follow the General Data Protection Regulation (GDPR), the European Union's privacy law which has been active since 2018. This requires the company to only collect information for necessary purposes and requires it to keep all personal data of its patients secure while operating transparently, fairly, and lawfully (European Union, 2016). This applies to all business industries operating in the European Union, but health data is classified as a "Special Category" and needs to be kept extra secure. However, if a company outside of the European Union handles any European resident's data, the company is not exempt from these laws. Because of this cross-border collaboration between the companies, compliance under the GDPR is mandatory (TeleMedica, n.d.).

TeleMedica's policy shows that it is compliant with the GDPR because the company requires that all patient data be "processed lawfully, transparently, and securely" (TeleMedica, n.d.). This is the exact language that is outlined within the principles in Article 5 of the GDPR. Furthermore, all the data that is transmitted between TeleMedica, MediCom GmbH, and other third-party health providers occurs over a VPN, which protects the sensitive patient data of European Union residents when the companies share data across borders.

Every health company that is based around technology must comply with the Health Information Technology for Economic and Clinical Health (HITECH) Act, which was first passed in 2009. This new legislation strengthened HIPAA by adding a Breach Notification Rule, which requires every organization in this industry to detect breaches of unsecured health information. Once detected, it must notify consumers as well as the Department of Health and Human Services about reported breaches within 60 days or it will face heavy penalties for these violations (U.S. Department of Health and Human Services, 2017). TeleMedica's entire business model is based on processing health information electronically. Additionally, it uses health technology such as AI-driven diagnostic systems, live video consultations, and remote health monitoring. While HIPAA sets national standards for all healthcare providers, HITECH applies specifically to companies in the health information technology industry (TeleMedica, n.d.).

Based on the Incident Response Policy, all employees are required to report all security incidents immediately. Every incident is logged and reviewed quarterly. When an incident happens, a deep analysis behind the root cause is conducted to set in place new corrective measures to prevent it from recurring. These protocols show TeleMedica's ability to identify incidents when they occur and report breaches quickly, which is exactly what HITECH's Breach Notification Rule requires for all health information technology companies (TeleMedica, n.d.).

F. The three procedural and policy failures identified in TeleMedica's operations leave the company vulnerable to attacks and law violations. The first failure discovered was that TeleMedica encrypts its data using an outdated security protocol. It uses Secure Sockets Layer version 2.0 (SSL.v2) which was a protocol released in 1995 that quickly proved unreliable because of its weak key protection which left it vulnerable to attacks (TeleMedica, n.d.). In 2011, the SSL.v2 protocol was formally prohibited by internet standards (RFC 6176) and was later replaced by the Transport Layer Security (TLS). Because TeleMedica fails

to meet modern encryption standards, the company undermines HIPAA's Security Rule requirement to protect electronic protected health information in transit.

The second failure identified within TeleMedica is related to its policy behind password management. The company fails to implement multifactor authentication and relies entirely on its current system, which is a password change every 90 days for its employees (TeleMedica, n.d.). This kind of policy does not meet the expectations of the HIPAA Security Rule access control and industry baseline for sensitive systems. The 90-day password change also contradicts NIST SP 800-63B, which advises against password changes that happen periodically because they tend to force users to create weak passwords.

The last and final failure that was identified within TeleMedica is about its network log procedures. Its internal Security Operations Center (SOC) team reviews its network logs once a week manually. The problem with this is that it allows attackers to go unnoticed for up to seven days before anyone internally reviews the network logs (TeleMedica, n.d.). This violates HIPAA's Security Rule that requires regular review of system activity records and NIST SP 800-92 that recommends automated continuous monitoring. For a healthcare provider such as TeleMedica these procedures are not adequate to satisfy modern standards within its industry.

G. As stated previously, TeleMedica's first identified failure was its usage of Secure Sockets Layer version 2.0 (SSL.v2) protocol. Because it is an outdated protocol that is no longer the modern standard, my recommendation for the company is to transition from its previous encryption protocol to the modern Transport Layer Security (TLS) 1.2 as the minimum, with TLS 1.3 preferred, as recommended by NIST SP 800-52. This corrects the usage of the 2011 prohibited protocol and strengthens encryption, while also preventing attacks against the company. As a healthcare company,

ensuring every transmission of patient health data is protected should be prioritized over anything else. Following these changes restores HIPAA Security Rule compliance for electronic patient health information and GDPR security for EU data that flows between TeleMedica and MediCom GmbH across borders.

The correction I recommend for TeleMedica's password policy is to implement multifactor authentication across company systems, especially ones containing patient data. The 90-day password change requirement is not advised by NIST. Instead, I recommend the company remove this forced requirement. This will align the company's policies with NIST SP 800-63B as it removes the increased risk of weak passwords being made and prevents accounts from being compromised by attackers. Additionally, adding a second layer of security such as multifactor authentication keeps accounts secure. Since multiple authentication factors are now required to log in, it would be difficult for attackers to gain access through traditional methods such as phishing or brute forcing. This new methodology now aligns TeleMedica's access control with both the HIPAA Security Rule and current NIST guidance.

The final correction I would make for TeleMedica is an improvement that must be made to its network log review procedures. In its current state, the company only reviews network logs every week, which allows attackers up to seven days to exploit its systems. Instead of relying solely on manual weekly network log reviews, I recommend the company implement a security information and event management (SIEM) system that will continuously monitor logs and notify the SOC team immediately when suspicious activity is detected, as this will assist with faster containment of any suspicious activity. This recommendation satisfies NIST SP 800-92's log management guidance and HIPAA's expectation of regular system activity reviews.

References

California Department of Justice. (2024). California Consumer Privacy Act (CCPA). State of California Office of the Attorney General. <https://oag.ca.gov/privacy/ccpa>

European Union. (2016). Regulation (EU) 2016/679 (General Data Protection Regulation). Official Journal of the European Union. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>

International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information security management systems — Requirements. <https://www.iso.org/standard/27001>

National Institute of Standards and Technology. (2006). Guide to computer security log management (NIST Special Publication 800-92). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-92>

National Institute of Standards and Technology. (2008). Guide for mapping types of information and information systems to security categories (NIST Special Publication 800-60, Vol. 1, Rev. 1). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-60v1r1>

National Institute of Standards and Technology. (2012). Computer security incident handling guide (NIST Special Publication 800-61, Rev. 2). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-61r2>

National Institute of Standards and Technology. (2014). Guidelines for media sanitization (NIST Special Publication 800-88, Rev. 1). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-88r1>

National Institute of Standards and Technology. (2017). Digital identity guidelines: Authentication and lifecycle management (NIST Special Publication 800-63B). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-63b>

National Institute of Standards and Technology. (2018). Framework for improving critical infrastructure cybersecurity

(Version 1.1). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.CSWP.04162018>

National Institute of Standards and Technology. (2019). Guidelines for the selection, configuration, and use of Transport Layer Security (TLS) implementations (NIST Special Publication 800-52, Rev. 2). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.SP.800-52r2>

National Institute of Standards and Technology. (2020). NIST privacy framework: A tool for improving privacy through enterprise risk management (Version 1.0). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.CSWP.01162020>

National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>

TeleMedica. (n.d.). TeleMedica information security policy. Western Governors University.

U.S. Department of Health and Human Services. (2013). Summary of the HIPAA Security Rule. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>

U.S. Department of Health and Human Services. (2017). HITECH Act enforcement interim final rule. <https://www.hhs.gov/hipaa/for-professionals/special-topics/hitech-act-enforcement-interim-final-rule/index.html>